

ENTERPRISE SECURITY ASSESSMENT LAB

AD NETWORK SECURITY METHODOLOGY REPORT

Phase 4 - Validating recovered credentials against SMB/domain services

Report Section	Phase 04 - SMB Credential Validation and Domain Enumeration
Project Area	Internal Network and Active Directory Security Assessment
Environment	Private Windows AD lab - Kali Linux, Windows Server, Windows endpoint
Prepared For	GitHub Portfolio Documentation
Document Type	Individual methodology PDF with redacted evidence

Authorized lab documentation only. Sensitive credential material, hashes, passwords, and replication output have been redacted before publication.

1. Executive Summary

This report documents **SMB Credential Validation and Domain Enumeration** as part of the AD Network module in the Enterprise Security Assessment Lab. The section is written as a professional, portfolio-safe methodology report that explains the testing objective, workflow, evidence, tool usage, sanitized output, security risk, remediation guidance, and GitHub publication requirements.

Objective: Validate whether recovered credentials are accepted by SMB/domain services and determine what level of enumeration is possible with the authenticated account.

MITRE / Framework Mapping	Credential Access and Discovery workflow - related to Account Discovery (T1087) and Remote System Discovery (T1018)
Testing Scope	Authorized private Active Directory lab only
Evidence Handling	Screenshots embedded with necessary redaction; raw hashes and secrets are not included

2. Methodology and Workflow

The methodology below is designed to show a controlled penetration-testing workflow rather than random tool execution. Each step supports a specific assessment goal and produces evidence that can be reviewed safely in a public portfolio.

- Use the recovered lab credential from the cracking phase.
- Validate authentication against SMB without attempting destructive actions.
- Enumerate shares and basic domain information only inside the lab scope.
- Record where access is allowed and where access is denied.
- Use the results to decide whether Kerberos or BloodHound testing is justified.

Command / Workflow Used

```
# Example credential validation workflow
netexec smb <DC_IP> -u <REDACTED_USER> -p '<REDACTED_PASSWORD>'

# Alternative tool
crackmapexec smb <DC_IP> -u <REDACTED_USER> -p '<REDACTED_PASSWORD>'

# Enumerate shares or users when authorized
netexec smb <DC_IP> -u <REDACTED_USER> -p '<REDACTED_PASSWORD>' --shares
```

Sanitized Output Style

```
SMB authentication: VALID
Accessible shares: <SANITIZED_LIST>
Domain users/groups: <SANITIZED_OUTPUT>
Privilege status: controlled lab validation only
```

3. Evidence Mapping and Screenshot Explanation

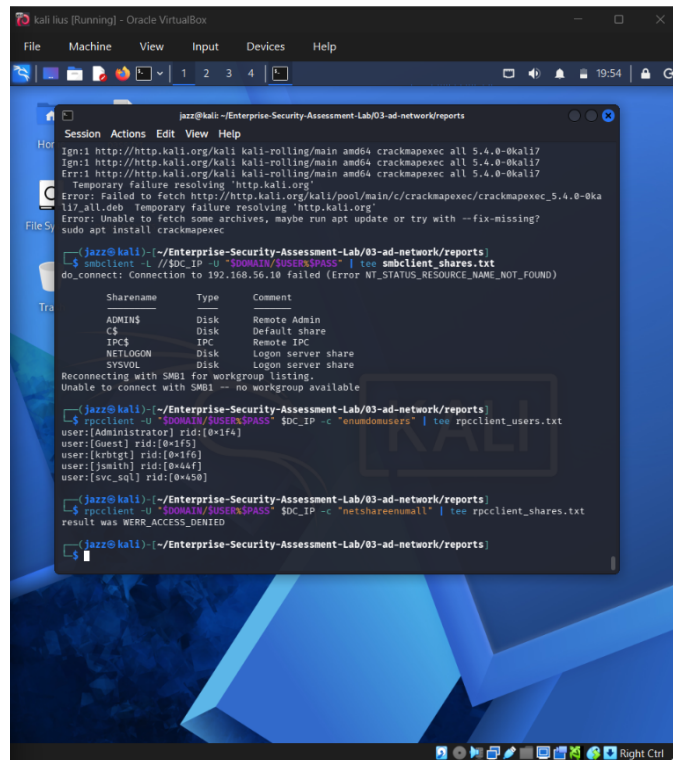


Figure - SMB credential validation and enumeration

This screenshot shows SMB/domain enumeration activity using sanitized credential placeholders.

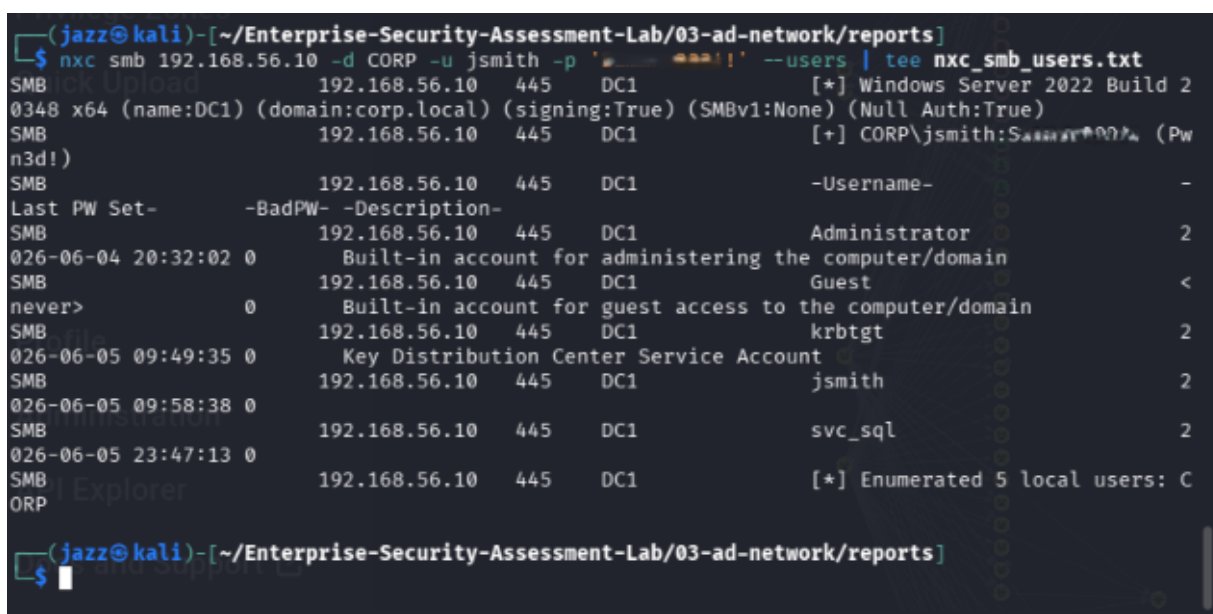


Figure - NetExec SMB enumeration output part 1

This evidence shows authenticated SMB enumeration output from the lab environment.

```
(jazz@kali)-[~/Enterprise-Security-Assessment-Lab/03-ad-network/reports]
$ cd ~/Enterprise-Security-Assessment-Lab/03-ad-network/reports

(jazz@kali)-[~/Enterprise-Security-Assessment-Lab/03-ad-network/reports]
$ nxc smb 192.168.56.10 -d CORP -u jsmith -p 'Summer2024!' --shares | tee nxc_smb_shares.txt
SMB 192.168.56.10 445 DC1 [+] Windows Server 2022 Build 2
0348 x64 (name:DC1) (domain:corp.local) (signing:True) (SMBv1:None) (Null Auth:True)
SMB 192.168.56.10 445 DC1 [+] CORP\jsmith:Summer2024! (Pw
n3d!)
SMB 192.168.56.10 445 DC1 [+] Enumerated shares
SMB 192.168.56.10 445 DC1 Share Permissions
Remark
SMB 192.168.56.10 445 DC1
SMB 192.168.56.10 445 DC1 ADMIN$ READ,WRITE
Remote Admin
SMB 192.168.56.10 445 DC1 C$ READ,WRITE
Default share
SMB 192.168.56.10 445 DC1 IPC$ READ
Remote IPC
SMB 192.168.56.10 445 DC1 NETLOGON READ,WRITE
Logon server share
SMB 192.168.56.10 445 DC1 SYSVOL READ,WRITE
Logon server share
```

Figure - NetExec SMB enumeration output part 2

This evidence shows additional SMB/domain enumeration detail after credential validation.

4. Technical Interpretation

The evidence is interpreted in the context of a private AD lab. The screenshot proves execution of the relevant technique or validation step, while the sanitized command and output blocks show how the result should be presented without exposing raw credential material.

What the evidence proves	The lab phase for SMB Credential Validation and Domain Enumeration was executed and documented.
What it does not prove	It does not indicate testing of any public, third-party, or production network.
Publication status	Safe for GitHub after redaction of sensitive values.

5. Risk Analysis

Valid credentials can turn a single captured hash into wider internal access. Even low-privileged users may enumerate shares, users, groups, naming conventions, or misconfigured access paths that support later privilege escalation.

Real-World Impact Categories

- Credential exposure or credential reuse risk
- Lateral movement or privilege escalation potential depending on account rights
- Domain visibility and attack path discovery in internal environments
- Operational and detection gaps if monitoring does not cover the relevant Windows, Kerberos, SMB, or LDAP events

6. Recommended Remediation

- Monitor successful and failed SMB authentication events.
- Restrict share access using least privilege.
- Remove unnecessary read access from domain users.
- Use tiered administration for privileged accounts.

- Investigate unusual enumeration patterns from workstations.

7. GitHub Redaction and Publication Guidance

- Publish only redacted evidence. Do not upload raw hashes, password material, ticket files, DCSync output, or secretsdump text dumps.
- Keep this report under 03-ad-network/reports/methodology/ and keep raw tool output in a private working folder unless fully sanitized.
- Use placeholders such as , , , and in public documentation.
- Confirm the screenshot file name in the README matches the repository file name exactly, including case, hyphens, and extension.

Do Not Upload

```
*.hash
*_hashes.txt
responder logs with raw NetNTLMv2
kerberoast_hashes.txt
secretsdump output
DCSync dumps
cracked-password files
unredacted BloodHound collection ZIPs if they expose sensitive names
raw command history containing passwords
```

8. Conclusion

The **SMB Credential Validation and Domain Enumeration** phase demonstrates a structured and evidence-based AD testing workflow. The report explains the purpose of the test, shows sanitized evidence, connects the activity to real-world risk, and provides practical remediation guidance. This makes it suitable for a professional cybersecurity GitHub portfolio.